

Lab 03: Testing SSH Security with Nmap and Hydra - Exercise Report

Introduction

The goal of this exercise was to understand basic SSH security. I used Nmap to find open ports and services and Hydra to test SSH passwords with a brute-force attack. This helped me understand the risks of weak passwords and unnecessary open ports.

Experiment

I built the Docker image, started the container, and found the target IP address. I then used Nmap to scan the system.

- Open port: 22/tcp
- Service: SSH (OpenSSH 8.9p1 Ubuntu)
- Operating System: Ubuntu 3ubuntu0.15

After verifying the SSH connection, I created a password list and used Hydra to test the SSH login. This showed how quickly weak passwords can be tested automatically.

```
(kali㉿kali)-[~/cybersecurity/CS-Vaje/lab03/dvws]
$ sudo docker rm -f dvws-ssh 86 sudo docker run -d -p 2223:22 --name dvws-ssh dvws

[sudo] password for kali:
dvws-ssh
6ae19ac1aa370d04b4c3b771df5cd629362c89fd305d83f736d30c2bee0215c9
```

```
(kali㉿kali)-[~/cybersecurity/CS-Vaje/lab03/dvws]
$ sudo docker inspect dvws-ssh | grep IPAddress
"SecondaryIPAddresses": null,
"IPAddress": "172.17.0.2",
"IPAddress": "172.17.0.2",
```

```
(kali㉿kali)-[~/cybersecurity/CS-Vaje/lab03/dvws]
$ nmap -sS -sV -O -p- 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-27 23:21 +0530
Nmap scan report for 172.17.0.2
Host is up (0.00014s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
MAC Address: 6A:F4:9E:07:DB:CE (Unknown)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=5/27%OT=22%CT=1%CU=43326%PV=Y%DS=1%DC=D%G=Y%M=6AF49E%T
OS:M=6A172F3D%P=x86_64-pc-linux-gnu)SEQ(SP=100%GCD=1%ISR=108%TI=Z%CI=Z%II=I
OS:%TS=21)SEQ(SP=103%GCD=1%ISR=108%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=106%GCD=1%ISR
OS:R=10C%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=107%GCD=1%ISR=10E%TI=Z%CI=Z%II=I%TS=22
OS:)SEQ(SP=FD%GCD=1%ISR=FF%TI=Z%CI=Z%II=I%TS=21)OPS(O1=M5B4ST11NWA%O2=M5B4S
OS:T11NWA%O3=M5B4NNT11NWA%O4=M5B4ST11NWA%O5=M5B4ST11NWA%O6=M5B4ST11)WIN(W1=
OS:FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=
OS:M5B4NNSNWA%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)
OS:T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=0%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S
OS:+%F=AR%O=0%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=0%RD=0%Q=)T7(R=Y%DF=
OS:Y%T=40%W=0%S=Z%A=S+%F=AR%O=0%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G
OS:%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.82 seconds
```

```
(kali㉿kali)-[~/cybersecurity/CS-Vaje/lab03/dvws]
$ ssh testuser@172.17.0.2 -p 22
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:48ZJWe2vvF47XtuRmy5Llk007tRieTUs06Zq8F9uBh8
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
testuser@172.17.0.2's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.19.14+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

testuser@6ae19ac1aa37:~$ ls
testuser@6ae19ac1aa37:~$
6ae19ac1aa37      ff00::          ip6-allnodes    ip6-localnet    localhost
::1              ip6-allrouters ip6-loopback
fe00::           ip6-localhost   ip6-mcastprefix
```

```
(kali㉿kali)-[~/cybersecurity/CS-Vaje/lab03/dvws]
$ echo -e "password
dquote> 123456
dquote> test123
dquote> admin"> passwords.txt

(kali㉿kali)-[~/cybersecurity/CS-Vaje/lab03/dvws]
$
```

```
(kali㉿kali)-[~/cybersecurity/CS-Vaje/lab03/dvws]
$ hydra -l testuser -P passwords.txt -s 22 172.17.0.2 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizati
ons, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-27 23:27:19
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t
4
[DATA] max 4 tasks per 1 server, overall 4 tasks, 4 login tries (l:1/p:4), ~1 try per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2  login: testuser  password: test123
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-27 23:27:22
```

Analysis and Report Summary

The Nmap scan showed that port 22/tcp was open and running SSH. Weak passwords such as test123, password, or 1234546 are dangerous because they are common and can be tested quickly with tools such as Hydra.

Unused ports should also be closed because they increase the attack surface, reveal running services, and may expose vulnerable software. Keeping only necessary ports open makes the system more secure.

1. How would you protect the SSH server from brute-force attacks?

I would use Fail2ban, strong passwords, SSH keys, rate limiting, and two-factor authentication. Changing the default SSH port can also reduce some automated scanning, although it should not replace proper security.

2. What additional measures would you recommend?

I would use a firewall such as UFW or iptables, disable root login, prefer SSH keys, limit login attempts, monitor SSH logs, and allow access only to approved users or groups.

3. How does the result change with a very strong password?

A strong password with 12 or more characters, using letters, numbers, and symbols, is much harder to crack. It is also less likely to appear in common wordlists such as rockyou.txt, so a brute-force attack would take much longer.

Port conflict:

I tried to use port 2222. I solved it by changing the port mapping from 2222 to 2223, and then continued the experiment.

Conclusion

This exercise helped me understand how open ports, SSH, and weak passwords can affect system security. Nmap helped identify the open SSH port, while Hydra showed the risk of weak passwords. I learned that SSH should be protected with strong authentication, limited access, and proper firewall settings.

Reference

- <https://infosecwriteups.com/10-essential-ssh-server-security-tips-best-practices-b5643e3d509b>
- https://nodeping.com/ssh_monitoring_best_practices.html
- <https://sanderknape.com/2016/11/securing-your-server-ssh-configuration/>